SQL Server Developer

Динамический SQL

otus.ru

• REC **Проверить, идет ли запись**

Меня хорошо видно && слышно?

Ставим “+”, если все хорошо
“-”, если есть проблемы

Динамический SQL

```
После занятия вы сможете
создавать процедуры с использованием динамического SQL;
перечислять ошибки при использовании динамического SQL,
        которые ведут к угрозам безопасности;
объяснить как можно сохранять план запроса по динамическому  SQL.

Краткое содержание
разница между Exec и sp_executesql;
примеры динамического sql, когда его стоит использовать;
процедуры типа "Kitchen sink";
SQL injections и как их избежать.

Домашние задания
Динамический PIVOT
```

Активно участвуем

Off-topic обсуждаем в учебной группе telegram

Задаем вопрос в чат или голосом

Вопросы вижу в чате, могу ответить не сразу

Динамический SQL

- Динамический – текст запроса формируется во время выполнения
  - собирается строка запроса
  - которая выполняется как обычная SQL-инструкция

```
-- объявили СТРОКОВУЮ переменную и сразу присвоили значение
declare @s nvarchar(max)
set @s = N'select * from table1'

-- выполнение кода из @s
exec (@s) -- вариант 1
exec sp_executesql @s -- вариант 2
```

- Динамика нужна, когда меняется структура запроса

Где используется

Игровые | 17 дюймов | 15 дюймов | Ультрабуки | 14 дюймов | MacBook | Трансформеры | Intel i7 | Intel i5

Сортировка: сначала недорогие Группировка: отсутствует

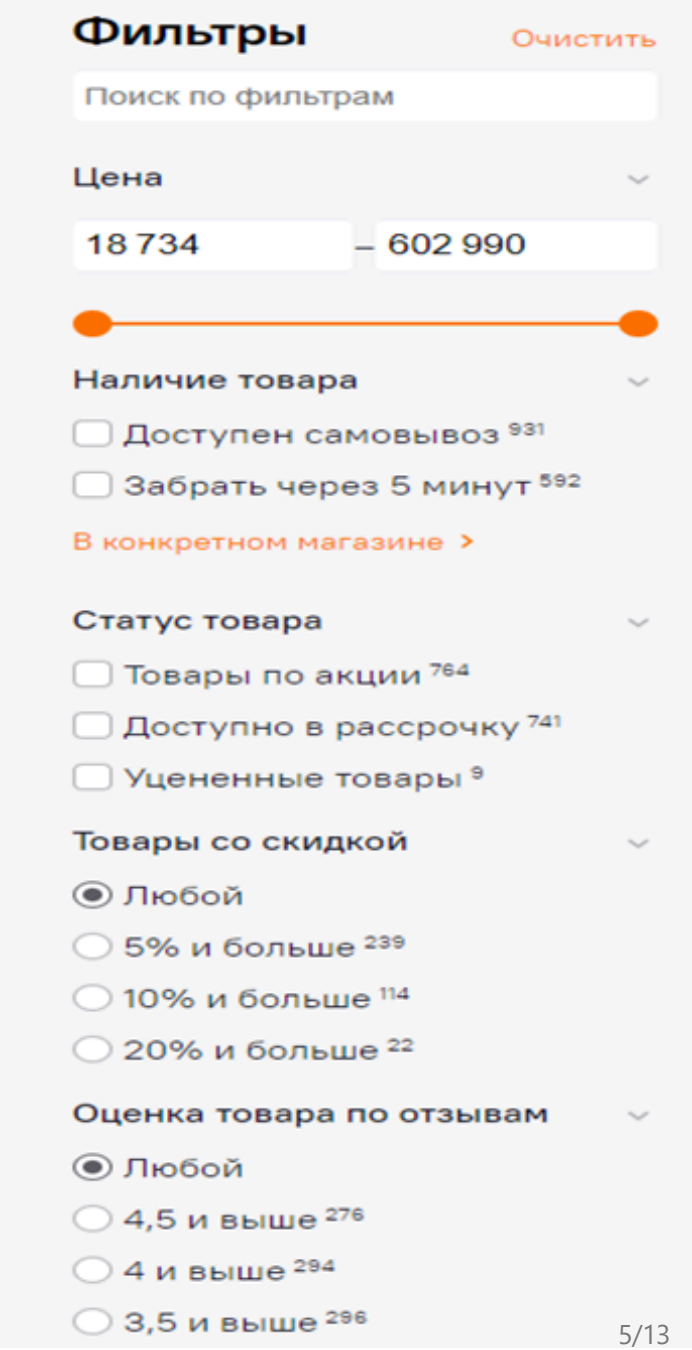
```
-- 1. в зависимости от выбора пользователя меняются фильтры
select * from t where ...

-- 2. порядок колонок в сортировке @list определяет пользователь
select * from t order by @list

-- 3. pivot
-- все клиенты -> в колонки, а список клиентов заранее не известен
select *
from (select name, qty from customers) t
pivot (
        max(qty)
        for name in (@list) -- список клиентов (заранее неизвестен)
) pvt

-- 4. выборка из разных таблиц, имя таблицы определяется параметром (длинный, однотипный код)
if @p = 'A'
        select col from t_A
...
else if @p = 'Z'
        select col from t_Z
```

если можно без динамики - пишем без динамики



Вариант1 - exec

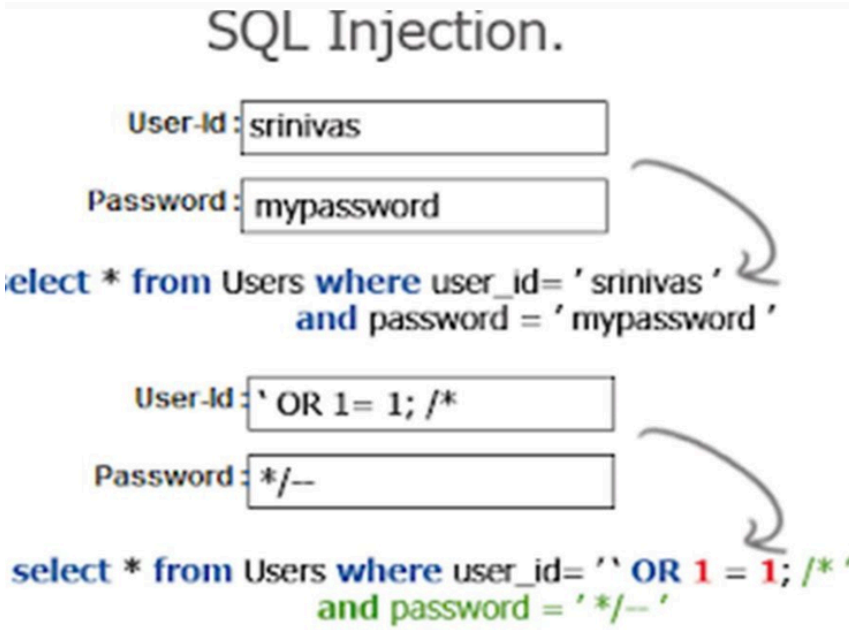
- поддерживает конкатенацию строк и/или переменных
- ❌ **нет параметров** → SQL Injection
- ❌ каждый раз новый план выполнения
- ❌ хуже для кеша планов

```
-- упрощенно!
-- авторизация пользователя на сайте
-- форма для ввода login-password
-- ожидание
declare @s nvarchar(max)
set @s = N'select * from users where login = '''
        + @login -- <- ввели в форме
        + ''' and password = '''
        + @password + '''' -- <- ввели в форме
print @s
select name from users where login = 'Alice' and password = 'pa$$word'
exec (@s)
if @@rowcount > 0 print 'Success!'
```

exec и SQL Injections

```
-- реальность
declare @s nvarchar(max)
set @s = N'select * from users where login = '''
        + @login -- <- ввели в форме
        + ''' and password = '''
        + @password + '''' -- <- ввели в форме
print @s
select name from users where login = or 1=1; /* and password = '*/--
exec (@s)
```

- SQL Injections - термин, обозначающий внедрение вредоносного кода
  ❌ подрыв логики приложения
  ❌ изучение базы данных
  `UNION select @@version`
- *на самом деле так уже давно никто не пишет, а используют параметризованные запросы (sp_executesql)*



sp_executesql

- системная хп, которая выполняет SQL инструкции
- ✓ параметры
- ✓ защита от SQL Injection
- ✓ кэширование планов запросов (производительность при многократных вызовах)

```
declare @sql nvarchar(max) = N'select * from users where id = @id';
exec sp_executesql @sql, N'@Id int', @Id = @Id;
```

https://docs.microsoft.com/ru-ru/sql/relational-databases/system-stored-procedures/sp-executesql-transact-sql?view=sql-server-ver17

Защита от SQL Injections

1. параметры
2. имена объектов - `QUOTENAME()`
3. не собирайте запрос конкатенируя параметры – ни в БД ни в приложении (по возможности используйте `sp_executesql`)
4. ограничивайте права пользователя, который использует приложение

demo

Хп типа Kitchen sink

- аналогия с раковиной (sink) на кухне, которая собирает всю посуду
- kitchen sink query собирает все возможные элементы запроса в одном месте
- хп с большим кол-вом параметров и сложной логикой их применения

Kitchen sink (антипаттерн)

- ❌ сложная логика
- ❌ плохие планы
- ❌ parameter sniffing
- ❌ трудно тестировать

Что можем сделать

- динамический SQL внутри хп

```sql
CREATE or alter PROCEDURE dbo.OrdersSearch_KitchenSink @OrderId INT = NULL
    ,@CustomerID INT = NULL
    ,@OrderDateFrom DATE = NULL
    ,@OrderDateTo DATE = NULL
    ,@SalespersonPersonID INT = NULL
AS
BEGIN
    SET NOCOUNT ON;

    SELECT OrderId,OrderDate,CustomerID,SalespersonPersonID
    FROM Sales.Orders
    WHERE (@CustomerID IS NULL OR CustomerID = @CustomerID)
        AND (@OrderId IS NULL OR OrderId = @OrderId)
        AND (OrderDate >= COALESCE(@OrderDateFrom, OrderDate))
        AND (@OrderDateTo IS NULL OR OrderDate <= @OrderDateTo)
        AND (@SalespersonPersonID IS NULL OR SalespersonPersonID = @SalespersonPersonID);
END
```

Вопросы?

Ставим “+”,
если вопросы есть

Ставим “–”,
если вопросов нет

Заполните, пожалуйста, опрос о занятии по ссылке в чате